

SIMATS ENGINEERING

ASSESSMENT TOOL 3

COURSE CODE: CSA5117 COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO5: *Develop the network security strategies based on the study of viruses, worms, firewall architectures, and IDS/IPS functionalities.CO (BL5, BL6)*

Assessment Tool Weightage: 10%

QUESTIONS: 20 TOTAL MARKS: 20 Annexure A MOCK INTERVIEW

Code of Conduct:

I Daniel Jesuraji J (192565085) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Annexure A MOCK INTERVIEW

1. Analyze the weaknesses of SSL and explain why TLS is considered more secure in modern web systems.

SSL Weaknesses:

- Uses outdated encryption algorithms (MD5, SHA-1).
- Vulnerable to attacks like POODLE and BEAST.
- Weak key exchange mechanisms.

- Poor message authentication.

Why TLS is Better:

- Uses stronger encryption (AES, ChaCha20).
- Supports secure key exchange (ECDHE).
- Provides forward secrecy.
- Better integrity with SHA-256 and authenticated encryption.

Conclusion: TLS is the modern standard because it offers stronger confidentiality, integrity, and authentication.

2. Apply the TLS handshake process to explain how secure session keys are established between a client and server.

The **TLS handshake** is a process used by a client and server to authenticate each other and securely establish a **shared session key** before exchanging data.

Steps involved:

1. **ClientHello:**

The client sends a *ClientHello* message containing the TLS version, a random value, and the supported cipher suites.

2. **ServerHello:**

The server responds with a *ServerHello*, selects the TLS version and cipher suite, and sends its random value.

3. **Server Authentication:**

The server sends its **digital certificate**, which contains its public key. The client verifies the certificate using a trusted Certificate Authority (CA).

4. **Key Exchange:**

The client and server exchange key-exchange information, commonly using **ECDHE (Elliptic Curve Diffie-Hellman Ephemeral)**.

5. **Session Key Generation:**

Both sides independently calculate the same **shared secret** from the exchanged key material. This shared secret is used to derive symmetric **session keys**.

6. **Finished Messages:**

Both client and server verify that the handshake was completed correctly.

7. **Secure Communication:**

After the handshake, the client and server use the generated **symmetric session keys** to encrypt and authenticate application data.

Conclusion:

The TLS handshake securely establishes session keys without directly transmitting the secret key over the network. It provides **authentication, confidentiality, and data integrity** for communication between the client and server.

3. Compare SSL and TLS in terms of encryption mechanisms and identify key improvements in TLS.

Feature	SSL	TLS
Security	Less secure	Highly secure
Encryption	RC4, DES	AES, ChaCha20
Integrity	MD5/SHA-1	SHA-256+
Forward Secrecy	No	Yes
Status	Deprecated	Current standard

Key Improvement: TLS provides stronger encryption and protection against modern cyberattacks.

4. Evaluate a scenario where improper certificate validation in TLS leads to a security breach. What could go wrong?

Scenario: A banking app accepts any certificate without verifying its authenticity.
What Goes Wrong?

- An attacker performs a Man-in-the-Middle (MITM) attack.
- The user unknowingly connects to the attacker's server.
- Login credentials and banking data are stolen.
- Confidentiality and authentication are completely compromised.

5. Analyze the role of digital certificates in SSL/TLS and explain how they ensure authentication.

Digital certificates:

- Verify the server's identity.
- Are issued by trusted Certificate Authorities (CAs).
- Contain the server's public key and domain name.
- Prevent impersonation and MITM attacks.

Result: Users can trust they are communicating with the genuine website.

6. Apply your understanding of SET protocol to explain how it protects credit card transactions in e-commerce.

Secure Electronic Transaction (SET) protects payments by:

1. Authenticating the customer, merchant, and bank.
2. Encrypting credit card information.
3. Using digital signatures for integrity.
4. Ensuring merchants never see the customer's card details.

Benefit: Provides confidentiality, authentication, and non-repudiation.

7. Evaluate the limitations of the SET protocol in current online payment systems. 8. Compare SET protocol with TLS-based payment security and justify which is more practical today.
 - Complex implementation.
 - High processing cost.
 - Requires digital certificates for every participant.
 - Poor user experience.
 - Not widely supported by merchants.

Therefore: SET has largely been replaced by TLS-based payment systems.

8. Analyze a malware attack scenario and differentiate whether it is caused by a virus, worm, or Trojan.

Scenario: A malicious email attachment is opened, installs fake antivirus software, and steals passwords.

Answer: Trojan

Reason: It disguises itself as legitimate software and requires user action to execute.

10. Apply appropriate mitigation techniques for a worm attack spreading across a corporate network.

- Disconnect infected devices.
- Patch operating systems.
- Block vulnerable ports using firewalls.
- Update antivirus software.
- Segment the corporate network.
- Monitor traffic using IDS/IPS.

Outcome: Prevents the worm from spreading across the network.

11. Evaluate the impact of Trojan attacks on system confidentiality and integrity with an example scenario.

Example: An employee installs a fake PDF reader.

Impact:

- Confidentiality: Sensitive company files are stolen.
- Integrity: Important documents are modified.
- Availability: The attacker may install ransomware.

Overall: Trojans can cause severe financial and reputational damage.

12. Compare viruses, worms, and Trojans based on propagation method and system impact.

Feature	Virus	Worm	Trojan
Needs Host File	Yes	No	No

Self-Replicates	Yes	Yes	No
User Interaction	Usually	Not required	Required
Main Goal	Damage files	Spread rapidly	Steal data

13. Analyze the working of a packet-filtering firewall and identify its limitations in modern networks.

A packet-filtering firewall examines:

- Source IP
- Destination IP
- Port number
- Protocol

Limitations:

- Cannot inspect application data.
- Cannot detect malware in encrypted traffic.
- Vulnerable to IP spoofing.
- No awareness of connection state.

14. Apply firewall rules to block unauthorized access while allowing legitimate traffic in a given scenario.

Rule	Action
Allow HTTPS (443)	Allow
Allow SSH from Admin IP	Allow
Block Telnet (23)	Deny
Block Unknown Incoming Traffic	Deny

Result: Legitimate users access services while unauthorized traffic is blocked.

15. Evaluate the effectiveness of stateful inspection firewalls over stateless firewalls.

Feature	Stateless	Stateful
Tracks Sessions	No	Yes
Security	Basic	Advanced
Performance	Faster	Slightly slower
Attack Detection	Limited	Better

Evaluation: Stateful firewalls are more effective because they understand the context of network connections.

16. Compare different types of firewalls and recommend the most suitable one for an enterprise network.

Firewall Type	Purpose
Packet Filtering	Basic traffic filtering
Stateful Inspection	Session-aware protection
Proxy Firewall	Application-level security
Next-Generation Firewall (NGFW)	Deep inspection, IDS/IPS, malware filtering

Recommendation: Next-Generation Firewall (NGFW) is the best choice for enterprise networks due to comprehensive protection.

17. Analyze how an IDS detects malicious activities using signature-based and anomaly-based techniques.

Technique	Detection Method
Signature-Based	Matches known attack patterns
Anomaly-Based	Detects unusual behavior from normal baseline

Example: A SQL injection is detected by signatures, while abnormal data transfers are detected by anomaly analysis.

18. Apply IDS/IPS mechanisms to prevent a distributed denial-of-service (DDoS) attack.

IDS:

- Detects abnormal traffic spikes.
- Alerts administrators.

IPS:

- Automatically blocks malicious IP addresses.
- Rate-limits excessive requests.
- Drops malicious packets before reaching the server.

Result: IPS actively reduces the impact of DDoS attacks.

19. Evaluate the differences between IDS and IPS in terms of response to detected threats.

Feature	IDS	IPS
Position	Monitors traffic	Inline with traffic
Response	Alerts only	Blocks attacks
Network Impact	None	May affect latency
Purpose	Detection	Prevention

Conclusion: IDS identifies threats, while IPS both detects and stops them.

20. Propose improvements to reduce false positives in an IDS while maintaining high detection accuracy.

Improvements:

- Regularly update attack signatures.
- Use machine learning for better anomaly detection.
- Fine-tune detection thresholds.
- Whitelist trusted applications and devices.
- Correlate alerts with threat intelligence.

Conclusion: Combining signature-based and anomaly-based detection improves accuracy while minimizing false positives.